DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY, DEVICE POSTURE, LOCATION, AND APPLICATION RISK.

Use Case Scenarios

Scenario 1: Finance Department Access to ERP System

A senior accountant in the finance department needs to access the corporate Enterprise Resource Planning (ERP) system to process monthly payroll. The user connects from a remote location using their company-managed laptop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with multi-factor authentication (MFA). ZPA evaluates the user's identity, group membership (Finance_ERP_Users), device posture (antivirus active, disk encryption enabled), and connection context. The policy engine determines that the user is authorized and brokers a secure, direct micro-tunnel to the ERP application only. The user can interact with the ERP interface, but has no visibility or network-level access to any other internal systems, such as development servers or the HR database.

Output:

- User authenticated and authorized based on identity and group membership
- Direct micro-tunnel established specifically to the ERP application
- All other internal applications and network segments remain invisible and inaccessible

Scenario 2: Contractor Access to Specific Project Repository

An external software consultant is hired for a three-month project and requires access only to a specific Git repository hosted on an internal server. The contractor is onboarded as a guest user in the identity provider and assigned to the "Project_X_Contractors" group. When the contractor connects using the ZPA client, the system verifies their identity and checks the device for basic security compliance (OS patch level, firewall enabled). ZPA enforces a policy that grants access exclusively to the Git repository application (port 22/SSH or port 443/HTTPS) during business hours (9 AM to 5 PM). The contractor can clone, push, and pull code, but cannot discover or connect to any other internal resources, including the corporate intranet or file servers.

Output:

• Time-bound and role-specific access enforced

• Contractor restricted to a single application (Git repository)

• Lateral movement to adjacent systems completely blocked

Scenario 3: Executive Access to Sensitive Financial Documents

A company VP needs to access a folder containing confidential M&A documents stored in a corporate SharePoint site. The user connects from a hotel business center while traveling internationally, using their companymanaged tablet. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, executive group membership, and device posture (which is compliant). However, the geolocation (unusual foreign country) and the application risk (highly sensitive document repository) trigger an elevated risk score. The policy engine grants access to the SharePoint site, but enforces additional restrictions: download and print capabilities are disabled, and the session is monitored for unusual behavior (e.g., mass download attempts). An alert is also sent to the security team for high-risk executive login.

Output:

• User authenticated with MFA and device compliant, but flagged for unusual location

• Read-only access granted with download/print restrictions enforced

• Security team alerted to potential credential misuse or espionage attempt

TITLE: DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY, DEVICE POSTURE, LOCATION, AND APPLICATION RISK.

COLLEGE NAME: KPR COLLEGE OF ARTS SCIENCE AND RESEARCH

DEPARTMENT: B.Sc. COMPUTER SCIENCE WITH DATA ANALYTICS

TEAM MEMBERS:

SNO	REGISTER NUMBER	NAME	COLLEGE	CONTACT
1	2328B0067	SARUMATHI P (TEAM LEADER)	KPRCAS	9789553710
2	2328B0019	CHANDAN SHILPA P D	KPRCAS	9566860205
3	2328B0028	HARSINI N	KPRCAS	9345621124
4	2328B0014	AKSHYA B	KPRCAS	6384908866
5	2328B0052	NUSHRATH S	KPRCAS	9789730080

Use Case Scenarios

Scenario 1: Finance Department Access to ERP System

A senior accountant in the finance department needs to access the corporate Enterprise Resource Planning (ERP) system to process monthly payroll. The user connects from a remote location using their company-managed laptop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with multi-factor authentication (MFA). ZPA evaluates the user's identity, group membership (Finance_ERP_Users), device posture (antivirus active, disk encryption enabled), and connection context. The policy engine determines that the user is authorized and brokers a secure, direct micro-tunnel to the ERP application only. The user can interact with the ERP interface, but has no visibility or network-level access to any other internal systems, such as development servers or the HR database.

Output:

- User authenticated and authorized based on identity and group membership
- Direct micro-tunnel established specifically to the ERP application
- All other internal applications and network segments remain invisible and inaccessible

Scenario 2: Contractor Access to Specific Project Repository

An external software consultant is hired for a three-month project and requires access only to a specific Git repository hosted on an internal server. The contractor is onboarded as a guest user in the identity provider and assigned to the "Project_X_Contractors" group. When the contractor connects using the ZPA client, the system verifies their identity and checks the device for basic security compliance (OS patch level, firewall enabled). ZPA enforces a policy that grants access exclusively to the Git repository application (port 22/SSH or port 443/HTTPS) during business hours (9 AM to 5 PM). The contractor can clone, push, and pull code, but cannot discover or connect to any other internal resources, including the corporate intranet or file servers.

Output:

• Time-bound and role-specific access enforced

• Contractor restricted to a single application (Git repository)

• Lateral movement to adjacent systems completely blocked

Scenario 3: Executive Access to Sensitive Financial Documents

A company VP needs to access a folder containing confidential M&A documents stored in a corporate SharePoint site. The user connects from a hotel business center while traveling internationally, using their companymanaged tablet. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, executive group membership, and device posture (which is compliant). However, the geolocation (unusual foreign country) and the application risk (highly sensitive document repository) trigger an elevated risk score. The policy engine grants access to the SharePoint site, but enforces additional restrictions: download and print capabilities are disabled, and the session is monitored for unusual behavior (e.g., mass download attempts). An alert is also sent to the security team for high-risk executive login.

Output:

• User authenticated with MFA and device compliant, but flagged for unusual location

• Read-only access granted with download/print restrictions enforced

• Security team alerted to potential credential misuse or espionage attempt

Scenario 4: Remote Support Technician Access to Internal Tools

An IT support technician needs to access the corporate ServiceNow instance and a remote desktop tool to assist an employee. The technician connects from their home office using a company-managed desktop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, group membership (IT_Support), device posture (fully compliant), and connection type (home office, which is whitelisted for IT staff). Because the user, device, and location all meet the baseline, the policy

engine grants direct micro-tunnel access to both ServiceNow and the specific remote desktop jump host used for employee support. The technician can perform their duties efficiently, but still has no access to finance systems, HR databases, or source code repositories.

Output:

• User authenticated and fully authorized based on trusted context

• Direct micro-tunnels established to ServiceNow and the remote desktop jump host

• Least-privilege access maintained; unrelated internal systems remain invisible

Scenario 5: High-Risk Application Access from a Low-Trust Location

A marketing coordinator needs to access the corporate Salesforce instance to update a campaign. The user connects from a coffee shop using their company-managed smartphone. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, group membership (Marketing_Salesforce_Users), device posture (managed and compliant), but flags the public Wi-Fi network as a high-risk connection. The policy engine determines that while the user and device are trusted, the network environment introduces unacceptable risk for direct access to a customer-facing CRM containing sensitive lead data. Instead of blocking access entirely, the user is routed through a secure ZPA browser isolation service, rendering the Salesforce session in a disposable container that prevents any data from persisting on the device or being exposed to the public network.

Output:

• User authenticated and device compliant, but network location deemed high-risk

• Access granted via browser isolation to prevent data leakage on public Wi-Fi

• Session is rendered in a secure container with copy/paste and download controls enforced

STAGE 1

ABSTRACT

With the rapid growth of digital technologies, organizations increasingly rely on web applications and online systems to store and process sensitive information. However, these systems are often targeted by cyber attackers who attempt to exploit security weaknesses. Traditional security methods that rely only on simple authentication mechanisms are no longer sufficient to protect modern applications.

This project focuses on designing and applying context-aware access control mechanisms based on user identity, device posture, location, and application risk. The objective of this approach is to improve the security of web applications by evaluating multiple contextual factors before granting access to users.

In addition to implementing access control concepts, vulnerability assessment and security testing were performed on target web applications using cybersecurity tools such as Nessus Scanner, Burp
Suite, and Kali Linux. The testing process helped identify various vulnerabilities including CrossSite Scripting, information exposure issues, and outdated software components.

The results obtained from the vulnerability analysis highlight potential security risks and demonstrate the importance of implementing proper security mechanisms such as input validation, secure configuration, and regular vulnerability scanning. This project emphasizes the role of modern security practices and context-aware access control in protecting systems from cyber threats and improving overall application security.

INTRODUCTION

In today's interconnected digital world, web applications and online systems play a crucial role in business operations, communication, and data management. As organizations increasingly adopt cloud computing, remote work environments, and mobile devices, the traditional concept of network security boundaries has significantly changed. These changes have created new challenges in protecting sensitive data and preventing unauthorized access.

Cyber attackers continuously attempt to exploit vulnerabilities present in web applications and servers. Weak authentication systems, improper input validation, and poor configuration settings can lead to serious security issues such as data breaches, unauthorized access, and system compromise. Therefore, it is important to implement advanced security mechanisms that can effectively protect applications and digital assets.

This project introduces the concept of context-aware access control, which is a modern security approach that evaluates different contextual factors before granting access to a system. Instead of relying only on usernames and passwords, the system analyzes additional parameters such as user identity, device security posture, geographical location, and the risk level of the application being accessed.

Along with implementing access control concepts, the project also focuses on vulnerability assessment and security testing. Various cybersecurity tools such as Nessus Scanner, Burp Suite, and Kali Linux were used to identify security weaknesses in the target web application. The vulnerabilities detected during the scanning process were analyzed to understand their potential impact and security risks.

By combining context-aware access control and vulnerability analysis, this project aims to improve the security posture of web applications and demonstrate the importance of proactive cybersecurity practices in protecting modern digital environments.

OVERVIEW:

In today's digital environment, organizations face many cybersecurity threats when users access systems from different locations and devices. Traditional security methods that only rely on usernames and passwords are no longer sufficient to protect sensitive data.

This project focuses on designing and applying context-aware access control, which is a modern security approach that evaluates multiple factors before allowing access to an application. These factors include the user's identity, the security condition of the device, the location from which the user is accessing the system, and the risk level of the application.

The system analyzes these conditions in real time and decides whether to allow access, restrict certain actions, request additional authentication such as multi-factor authentication (MFA), or block the access completely.

The goal of this project is to improve cybersecurity by implementing a Zero Trust security model, where every access request is verified before granting permission. This helps organizations protect sensitive data, prevent unauthorized access, and ensure secure usage of applications from any device or location.

SNO	VULNERBILITY NAME	CWE NO
1	Cross Site Scripting (Stored)	CWE-79
2	Broken Access Control	CWE-285
3	SQL Injection	CWE- 89
4	Broken Authentication	CWE- 285
5	Insecure Direct Object Reference	CWE- 639
6	Security Misconfiguration	CWE- 732

7	Cross Site Request Forgery	CWE- 352
8	Cleartext Transmission of Sensitive Information	CWE- 319
9	Clickjacking	CWE-1021
10	Password Auto Completion Enabled	CWE- 310
11	DOM Based Cross Site Scripting	CWE-79
12	JQuery Multiple XSS	CWE- 79
13	Information Exposure (HTTP Header Internal IP Disclosure)	CWE- 200
14	Information Exposure (SSL Issues)	CWE- 200
15	Information Exposure (HTTP Issues)	CWE- 200
16	OS Identification Failed	CWE- 200

1. **Vulnerability Name: Cross-Site Scripting (Stored)**

CWE Number: CWE-79

Description : Cross-Site Scripting (XSS) is a web security vulnerability where attackers insert malicious scripts into a web application. These scripts are stored in the server and later executed in the browser of other users who visit the affected page.

Business Impact : This vulnerability can allow attackers to steal sensitive information such as user credentials, session cookies, or personal data. It can also allow attackers to perform actions on behalf of legitimate users.

Vulnerability Path: http://testfire.net/

Vulnerability Parameter:http://testfire.net/search.jsp?query='>alert('hacked')

Steps to Reproduce:

1. Open the website http://testfire.net/.
2. Navigate to the search box in the application.
3. Enter the script '>alert('hacked').
4. Submit the input.
5. A pop-up alert box appears showing “hacked”, confirming the XSS vulnerability.

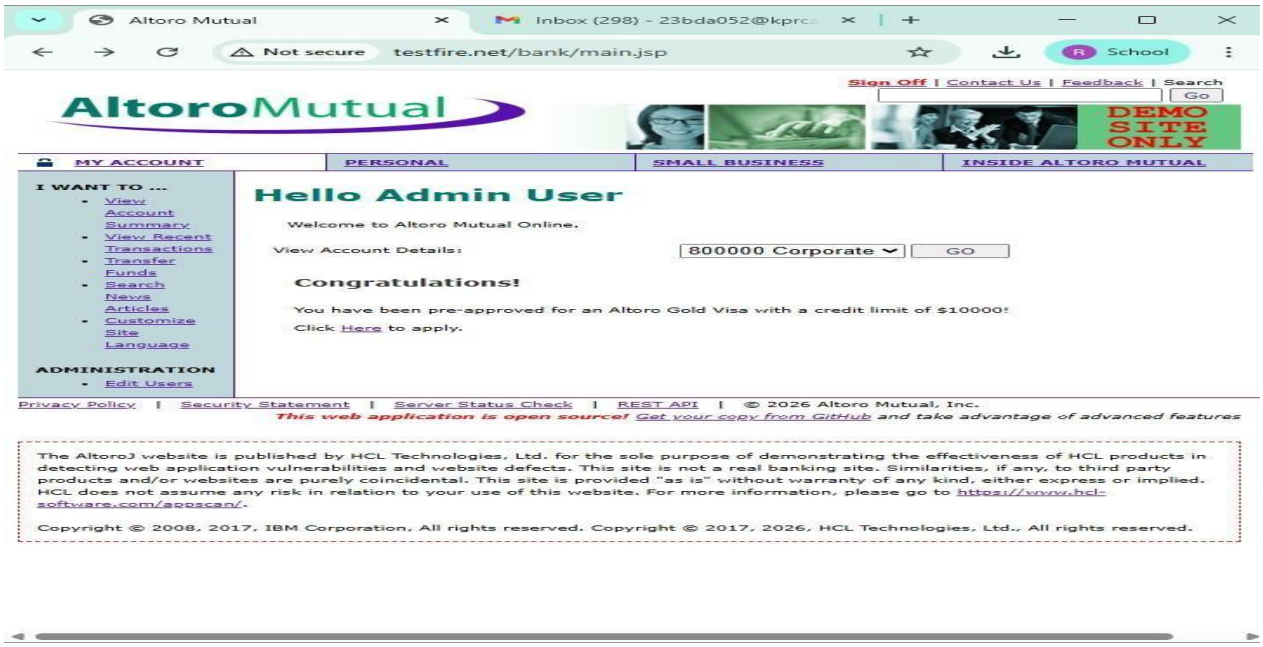
Recommendation:

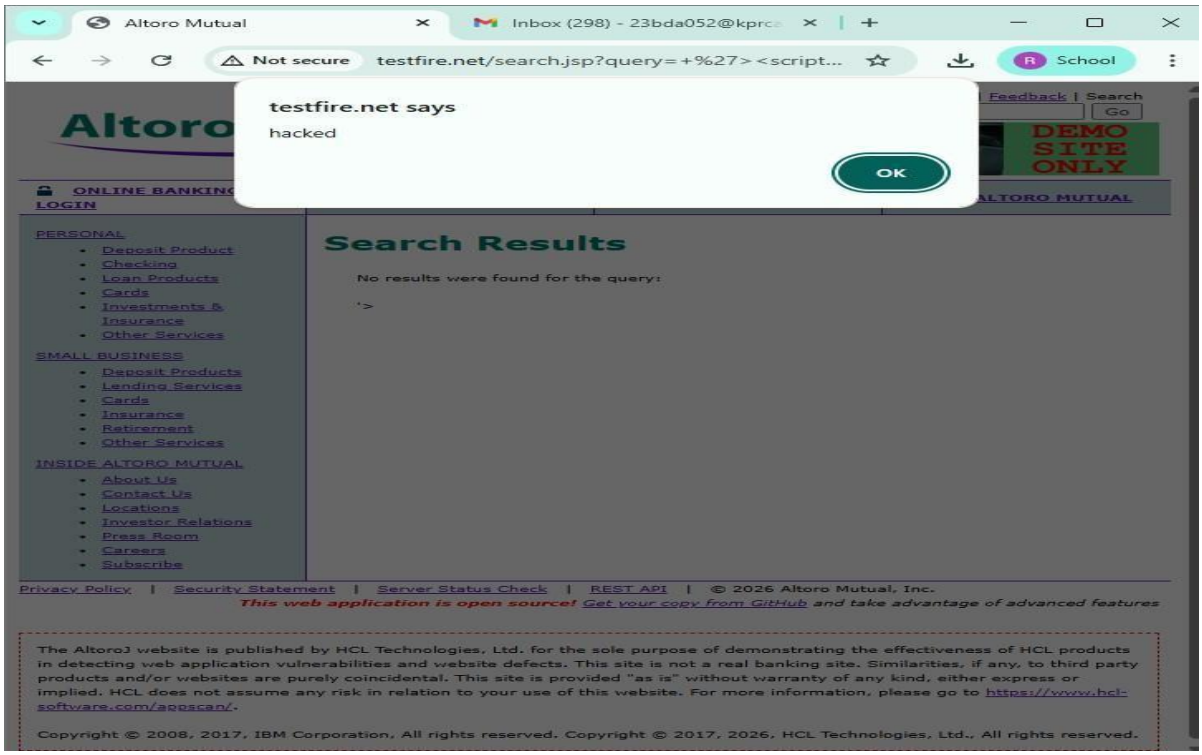
Validate and sanitize all user inputs.

Use output encoding to prevent script execution.

Implement secure coding practices to prevent injection attacks.

Screenshot:





2. Vulnerability Name : Broken Access Control

CWE No : CWE-285

Description : Broken Access Control occurs when a system does not properly restrict users from accessing data or functions that they are not authorized to use.

Business Impact : Attackers may gain unauthorized access to sensitive data, modify user information, or perform administrative actions. Vulnerability Path : http://testfire.net/login.jsp

Steps to Reproduce :

1. Open the website http://testfire.net/.
2. Try logging in using admin credentials.
3. Capture the request using Burp Suite.
4. The request shows username and password in clear text.

Recommendation :

Implement strong authentication and authorization mechanisms.

Use secure session management to protect user access.

Screenshot :

SkillWallet | Dashboard | Burp Proxy Setup | Altoro Mutual | Altoro Mutual

Not secure testfire.net/login.jsp

AltoroMutual

Sign Off | Contact Us | Feedback | Search Go

DEMO SITE ONLY

MY ACCOUNT | PERSONAL | SMALL BUSINESS | INSIDE ALTORO MUTUAL

PERSONAL
- Deposit Product
- Checking
- Loan Products
- Cards
- Investments & Insurance
- Other Services

SMALL BUSINESS
- Deposit Products
- Lending Services
- Cards
- Insurance
- Retirement
- Other Services

INSIDE ALTORO MUTUAL
- About Us
- Contact Us
- Locations
- Investor Relations
- Press Room
- Careers
- Subscribe

Online Banking Login

Username: admin

Password: •••••

Login

Privacy Policy | Security Statement | Server Status Check | REST API | © 2026 Altoro Mutual, Inc.

This web application is open source! Get your copy from GitHub and take advantage of advanced features

The Altoro website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to https://www.hcl-software.com/appscan/.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2026, HCL Technologies, Ltd., All rights reserved.

Burp Project Intruder Repeater View Help — Burp Suite Community Edition v2026.2.3 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on | Forward | Drop | Request to http://testfire.net:80 [65.61.137.117] | Open browser

Time	Type	Direction	Method	URL	Status code	Length
13:39:40 7 Mar...	HTTP	→ Request	GET	http://connectivitycheck.gstatic.com/generate_204		
13:51:26 7 Mar...	HTTP	→ Request	GET	http://testfire.net/bank/transaction.jsp		
13:55:16 7 Mar...	HTTP	→ Request	POST	http://testfire.net/doLogin		

Request

Pretty Raw Hex

```
POST /doLogin HTTP/1.1
Host: testfire.net
Content-Length: 37
Cache-Control: max-age=0
Origin: http://testfire.net
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://testfire.net/login.jsp
Accept-Encoding: gzip, deflate, br
Accept-Language: en-IN,en-GB;q=0.9,en;q=0.8
Cookie: JSESSIONID=813AB6312F53E67A9A8D20C831FD3A29; AltoroAccounts="ODAwMDAwfkNvcnBvcmF0ZX41LjIzNDUzMDgzNjY1NDMzRTd8ODAwMDAxfkNoZWNraW5nfjEwNTA1MS40NHw="
Connection: keep-alive

uid=admin&passw=admin&btnSubmit=Login
```

Inspector

- Request attributes 2
- Request query parameters 0
- Request body parameters 3
- Request cookies 2
- Request headers 13

Inspector | Notes

3. **Vulnerability Name : SQL Injection**

CWE No : CWE-89

Description : SQL Injection occurs when an attacker inserts malicious SQL queries into input fields to manipulate the database.

Business Impact : Attackers can access sensitive data, modify database records, or gain unauthorized administrative access.

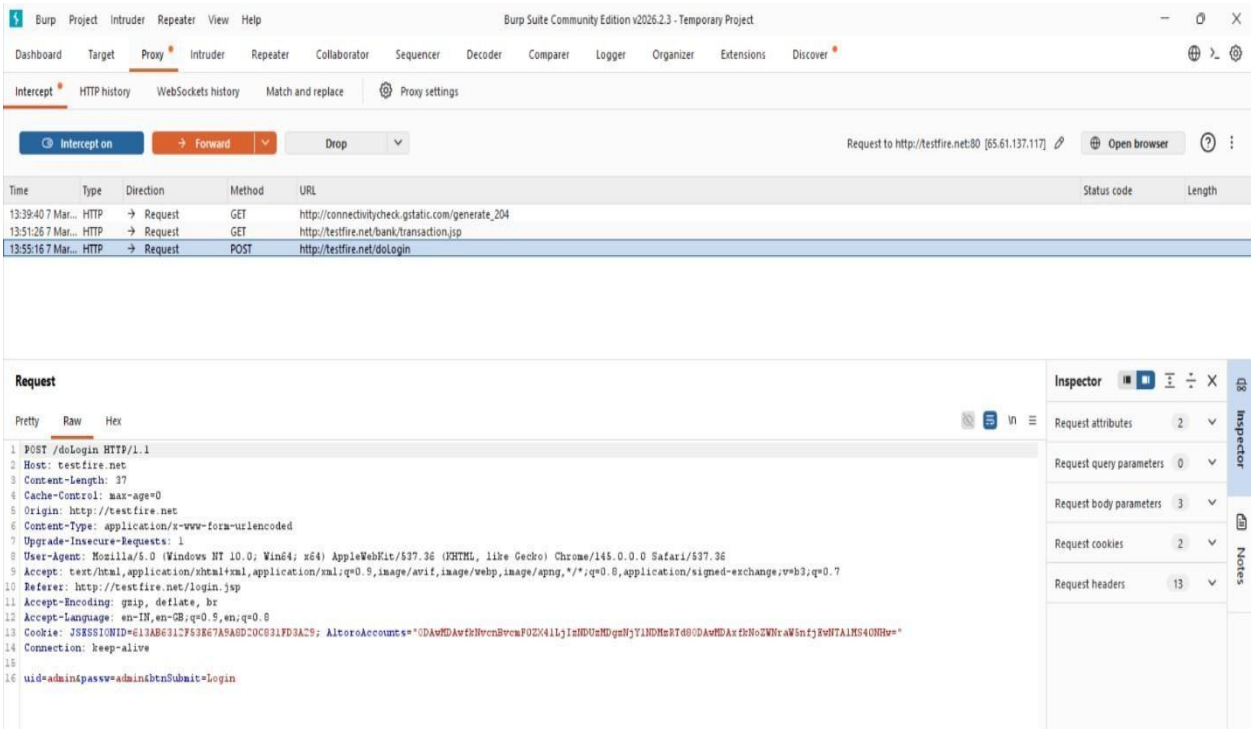
Vulnerability Path : http://testfire.net/login.jsp **Steps to Reproduce :**

1. Open the website http://testfire.net/.
2. Enter SQL injection payload in the login form.
3. Capture the request using Burp Suite.
4. The attacker may gain admin access without a valid password.

Recommendation :

Use parameterized queries or prepared statements.

Validate and sanitize all user inputs.



4. Vulnerability Name : Broken Authentication

CWE No : CWE-285

Description : Broken Authentication occurs when the system fails to properly manage user authentication. Attackers can bypass login mechanisms and access other user accounts. **Business Impact :** Attackers may gain unauthorized access to user accounts and sensitive information.

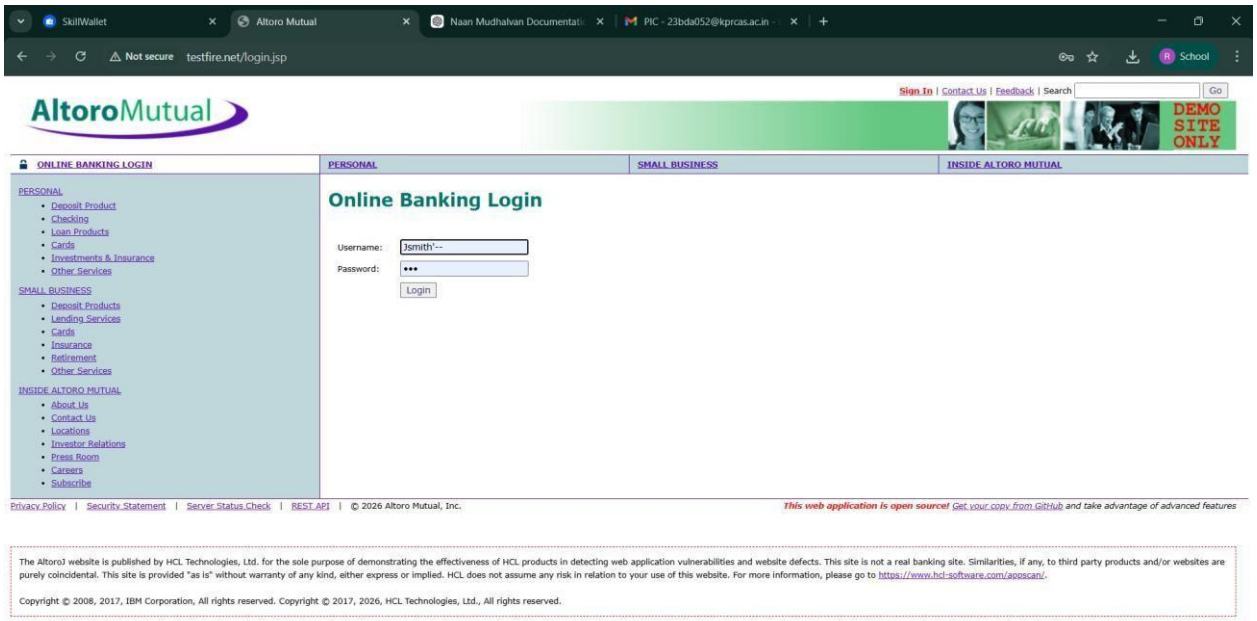
Vulnerability Path : http://testfire.net/login.jsp Steps to Reproduce :

1. Open the website **http://testfire.net/**.
2. Try logging in with manipulated username inputs.
3. Use SQL injection to bypass password verification.
4. Access to another user account is granted.

Recommendation :

Implement strong authentication mechanisms such as Multi-Factor Authentication (MFA).

Use secure password storage and proper session management.



5.Vulnerability Name : Insecure Direct Object Reference (IDOR)

CWE No : CWE-639

Description : IDOR occurs when a web application allows users to access or modify data by changing object identifiers such as user IDs or parameters in the URL.

Business Impact : Attackers can access or modify sensitive information of other users without proper authorization.

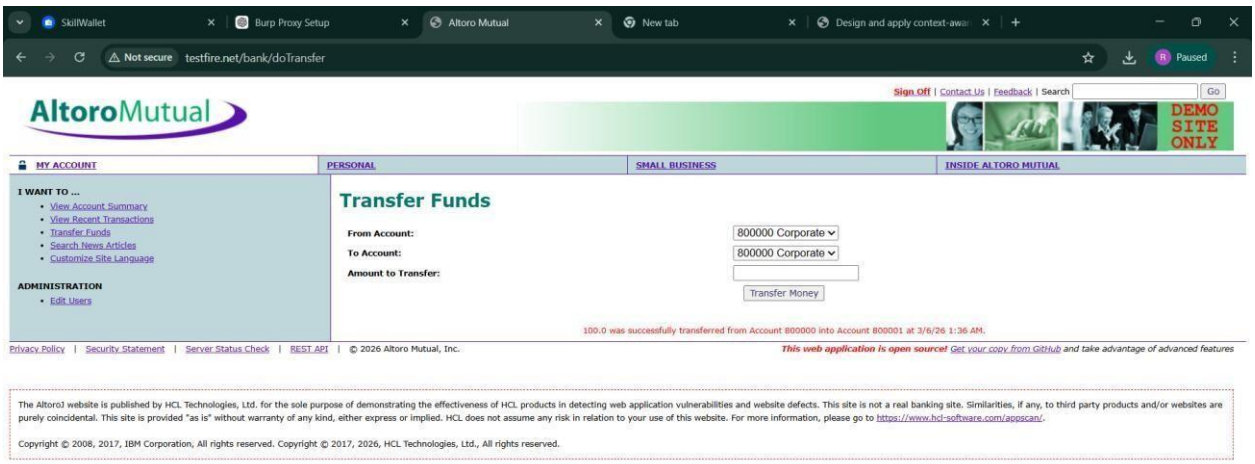
Vulnerability Path : **http://testfire.net/bank/transfer.jsp** **Steps to Reproduce :**

1. Open the website **http://testfire.net/**.
2. Login to the application.
3. Go to the "Transfer Money" section.
4. Intercept the request using Burp Suite and modify the transfer amount.

Recommendation :

Implement proper access control checks.

Validate user permissions before allowing access to sensitive data.



6. Vulnerability Name : Security Misconfiguration

CWE No : CWE-732

Description : Security Misconfiguration occurs when systems are not securely configured, allowing unauthorized access to sensitive files or directories.

Business Impact : Attackers may access confidential information, system files, or hidden directories due to weak security settings.

Vulnerability Path : **http://testfire.net/**

Steps to Reproduce :

1. Open the website **http://testfire.net/**.
2. Use scanning tools such as Uniscan in Kali Linux.
3. Scan the website for hidden directories.
4. The scan reveals accessible directories and sensitive files.

Recommendation :

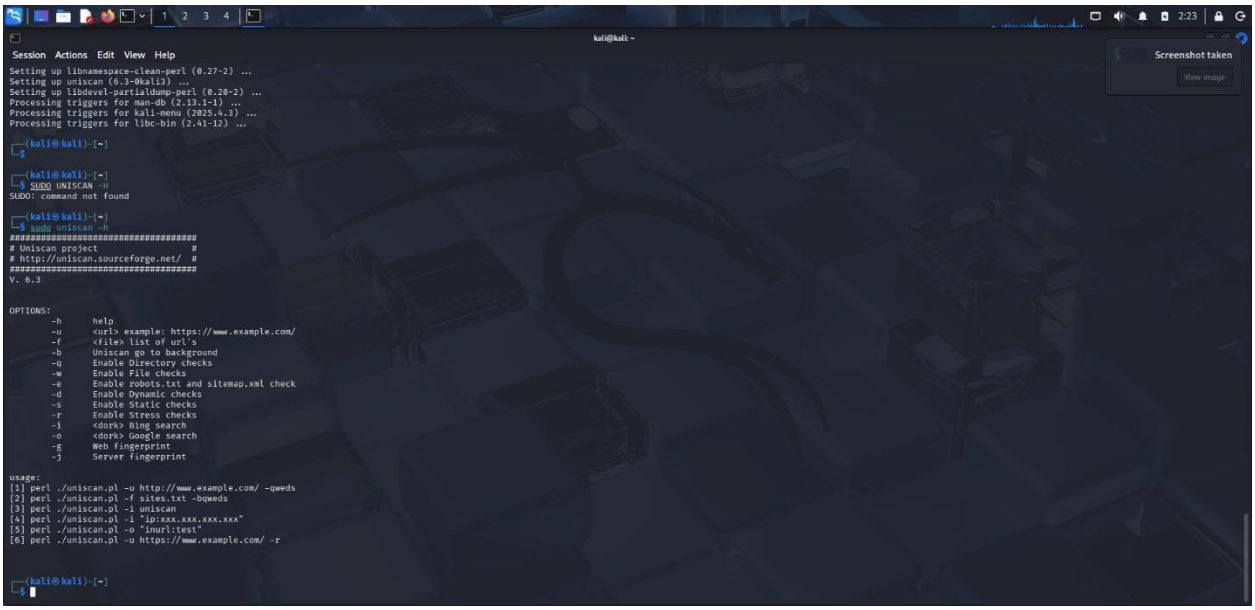
Apply secure configuration settings for servers and applications.

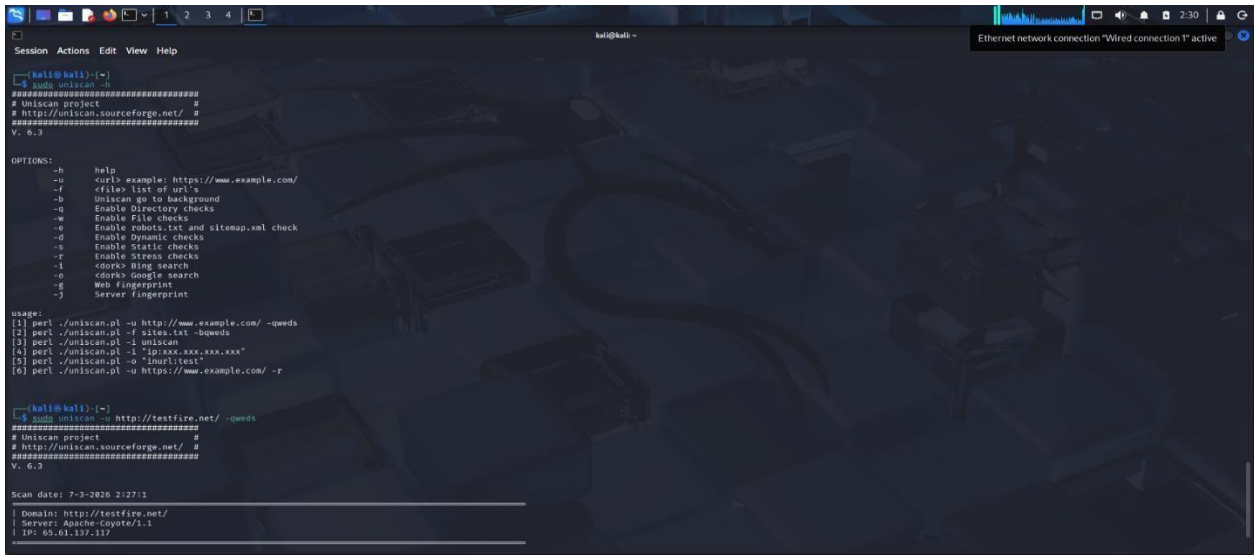
Regularly perform security audits and vulnerability scans.

Screenshot :

```
Session  Actions  Edit  View  Help
Setting up libnamespace-clean-perl (0.27-2) ...
Setting up uniscan (6.3-0kali3) ...
Setting up libdevel-partialdump-perl (0.20-2) ...
Processing triggers for man-db (2.13.1-1) ...
Processing triggers for kali-menu (2025.4.3) ...
Processing triggers for libc-bin (2.41-12) ...

┌──(kali㉿kali)-[~]
└─$

┌──(kali㉿kali)-[~]
└─$ SUDO UNISCAN -H
SUDO: command not found

┌──(kali㉿kali)-[~]
└─$ sudo uniscan -h
########################################
# Uniscan project                      #
# http://uniscan.sourceforge.net/      #
########################################
V. 6.3


OPTIONS:
        -h      help
        -u      <url> example: https://www.example.com/
        -f      <file> list of url's
        -b      Uniscan go to background
        -q      Enable Directory checks
        -w      Enable File checks
        -e      Enable robots.txt and sitemap.xml check
        -d      Enable Dynamic checks
        -s      Enable Static checks
        -r      Enable Stress checks
        -i      <dork> Bing search
        -o      <dork> Google search
        -g      Web fingerprint
        -j      Server fingerprint

usage:
[1] perl ./uniscan.pl -u http://www.example.com/ -qweds
[2] perl ./uniscan.pl -f sites.txt -bqweds
[3] perl ./uniscan.pl -i uniscan
[4] perl ./uniscan.pl -i "ip:xxx.xxx.xxx.xxx"
[5] perl ./uniscan.pl -o "inurl:test"
[6] perl ./uniscan.pl -u https://www.example.com/ -r


┌──(kali㉿kali)-[~]
└─$
```

```
Session  Actions  Edit  View  Help

┌──(kali㉿kali)-[~]
└─$ sudo uniscan -h
########################################
# Uniscan project                      #
# http://uniscan.sourceforge.net/      #
########################################
V. 6.3


OPTIONS:
        -h      help
        -u      <url> example: https://www.example.com/
        -f      <file> list of url's
        -b      Uniscan go to background
        -q      Enable Directory checks
        -w      Enable File checks
        -e      Enable robots.txt and sitemap.xml check
        -d      Enable Dynamic checks
        -s      Enable Static checks
        -r      Enable Stress checks
        -i      <dork> Bing search
        -o      <dork> Google search
        -g      Web fingerprint
        -j      Server fingerprint

usage:
[1] perl ./uniscan.pl -u http://www.example.com/ -qweds
[2] perl ./uniscan.pl -f sites.txt -bqweds
[3] perl ./uniscan.pl -i uniscan
[4] perl ./uniscan.pl -i "ip:xxx.xxx.xxx.xxx"
[5] perl ./uniscan.pl -o "inurl:test"
[6] perl ./uniscan.pl -u https://www.example.com/ -r


┌──(kali㉿kali)-[~]
└─$ sudo uniscan -u http://testfire.net/ -qweds
########################################
# Uniscan project                      #
# http://uniscan.sourceforge.net/      #
########################################
V. 6.3


Scan date: 7-3-2026 2:27:1
____________________________________________________________________________
| Domain: http://testfire.net/
| Server: Apache-Coyote/1.1
| IP: 65.61.137.117
____________________________________________________________________________
```





7. Vulnerability Name : Cross-Site Request Forgery (CSRF)

CWE No : CWE-352

Description : CSRF is an attack that tricks a logged-in user into performing unwanted actions on a web application without their knowledge.

Business Impact : Attackers can perform actions such as transferring funds or changing user data using the victim's authenticated session.

Vulnerability Path : **http://testfire.net/bank/transfer.jsp** **Steps to Reproduce :**

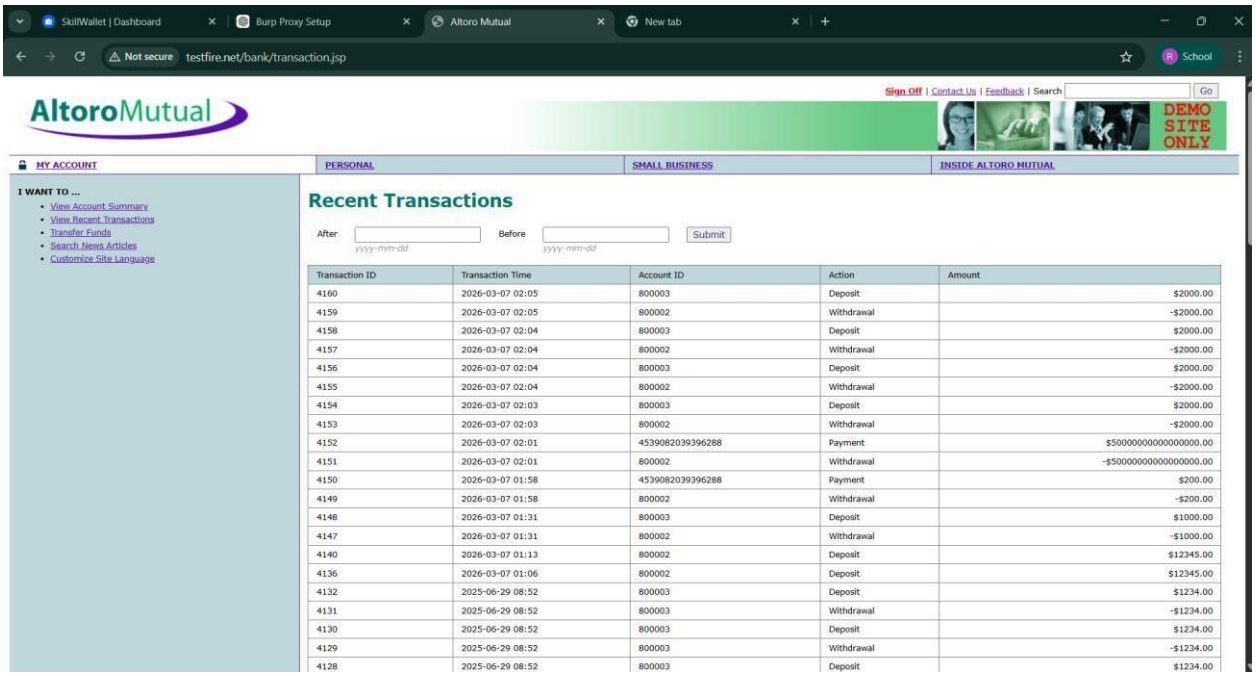
1. Open the website **http://testfire.net/**.
2. Login using valid credentials.
3. Capture the transfer request using Burp Suite.
4. Generate a CSRF proof-of-concept request to perform the action.

Recommendation :

Implement CSRF tokens to validate requests.

Use secure session management techniques.

Screenshot :



Transaction ID	Transaction Time	Account ID	Action	Amount
4160	2026-03-07 02:05	800003	Deposit	$2000.00
4159	2026-03-07 02:05	800002	Withdrawal	-$2000.00
4158	2026-03-07 02:04	800003	Deposit	$2000.00
4157	2026-03-07 02:04	800002	Withdrawal	-$2000.00
4156	2026-03-07 02:04	800003	Deposit	$2000.00
4155	2026-03-07 02:04	800002	Withdrawal	-$2000.00
4154	2026-03-07 02:03	800003	Deposit	$2000.00
4153	2026-03-07 02:03	800002	Withdrawal	-$2000.00
4152	2026-03-07 02:01	4539082039396288	Payment	$50000000000000000.00
4151	2026-03-07 02:01	800002	Withdrawal	-$50000000000000000.00
4150	2026-03-07 01:58	4539082039396288	Payment	$200.00
4149	2026-03-07 01:58	800002	Withdrawal	-$200.00
4148	2026-03-07 01:31	800003	Deposit	$1000.00
4147	2026-03-07 01:31	800002	Withdrawal	-$1000.00
4140	2026-03-07 01:13	800002	Deposit	$12345.00
4136	2026-03-07 01:06	800002	Deposit	$12345.00
4132	2025-06-29 08:52	800003	Deposit	$1234.00
4131	2025-06-29 08:52	800003	Withdrawal	-$1234.00
4130	2025-06-29 08:52	800003	Deposit	$1234.00
4129	2025-06-29 08:52	800003	Withdrawal	-$1234.00
4128	2025-06-29 08:52	800003	Deposit	$1234.00

Burp Project Intruder Repeater View Help — Burp Suite Community Edition v2

Dashboard | Target | Proxy | Intruder | Repeater | Collaborator | Sequencer | Decoder | Comparer | Logger

Intercept | HTTP history | WebSockets history | Match and replace | Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Exten
19	http://testfire.net	POST	/bank/doTransfer	✓		302	297		

Request

Pretty | Raw | Hex

```
1  POST /bank/doTransfer HTTP/1.1
2  Host: testfire.net
3  Content-Length: 79
4  Cache-Control: max-age=0
5  Origin: http://testfire.net
6  Content-Type: application/x-www-form-urlencoded
7  Upgrade-Insecure-Requests: 1
8  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
   (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
9  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,ima
   ge/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://testfire.net/bank/doTransfer
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: en-IN,en-GB;q=0.9,en;q=0.8
13 Cookie: JSESSIONID=613AB6312F53E67A9A8D20C831FD3A29; AltoroAccounts=
   "ODAwMDAyflNhdmluZ3N+MTAzNzgxNC40MTk50Tk50Tk5fDgwMDAwM35DaGVja2luZ340LjczNzg20T
   c2MzEyMDE4M0UyMHw0NTM5MDgyMDM5Mzk2Mjg4fkNyZWRpdCBDYXJkfi050S410Hw="
14 Connection: keep-alive
15
16 fromAccount=800002&toAccount=800003&transferAmount=2000&transfer=Transfer+Money
```

Response

Pretty | Raw | Hex | Re

```
1  HTTP/1.1 200 OK
2  Server: Apache-Coyote/
3  Content-Type: text/htm
4  Content-Length: 7360
5  Date: Sat, 07 Mar 2026
6
7
8
9
10
11
12
13
14 <!-- BEGIN HEADER -->
15 <!DOCTYPE html PUBLIC
   "http://www.w3.org/TR/
16
17 <html xmlns="http://ww
18
19
20
21   <head>
22     <title>
         Altoro Mutual
       </title>
23     <meta http-equiv="
24     <link href="/style
25   </head>
26   <body style="margin-
27
28     <div id="header" s
29       <form id="frmSea
```

Burp Project Intruder Repeater View Help — Burp Suite Community Edition v2026.2.3 - Temporary Pro...

Dashboard | Target | Proxy | Intruder | Repeater | Collaborator | Sequencer | Decoder

Comparer | Logger | Organizer | Extensions | Discover

1 ×

Send | Cancel | Target: http://testfire.net | HTTP/1

Request

Pretty | Raw | Hex

```
11 Accept-Encoding: gzip, deflat
12 Accept-Language: en-IN,en-GB;
13 Cookie: JSESSIONID=613AB6312F
   AltoroAccounts=
   "ODAwMDAyflNhdmluZ3N+MTAzNzgx
   35DaGVja2luZ340LjczNzg20Tc2Mz
   5Mzk2Mjg4fkNyZWRpdCBDYXJkfi05
14 Connection: keep-alive
15
16 fromAccount=800002&toAccount=
   2000&transfer=Transfer+Money
```

Search

Response

Scan
Send to Intruder Ctrl+I
Send to Repeater Ctrl+R
Send to Sequencer
Send to Comparer
Send to Decoder
Send to Organizer Ctrl+O
Insert Collaborator payload
Request in browser >
Engagement tools [Pro version only] > — Find references; Discover content; Schedule task; Generate CSRF PoC
Change request method
Change body encoding >
Copy Ctrl+C
Copy prettified Ctrl+Alt+C
Copy URL
Copy as curl command (bash)
Save selected text to file
Paste text from file
Save item
Save entire history
Paste host / URL as request
Add to site map
Convert selection >
URL-encode as you type
Cut Ctrl+X
Copy Ctrl+C
Paste Ctrl+V
Message editor documentation
Burp Repeater documentation

Inspector: est attributes 2; est query parameters 0; est body parameters 4; est cookies 2; 13

Inspector | Notes | Custom actions

Ready

Event log (81) | All issues | : 150.1MB of 3.67GB | Disabled

8. Vulnerability Name : Cleartext Transmission of Sensitive Information

CWE No : CWE-319

Description : This vulnerability occurs when sensitive information such as usernames and passwords is transmitted without encryption over the network.

Business Impact : Attackers can intercept network traffic and capture sensitive information, leading to data breaches and unauthorized access. **Vulnerability Path :**

http://testfire.net/login.jsp **Steps to Reproduce :**

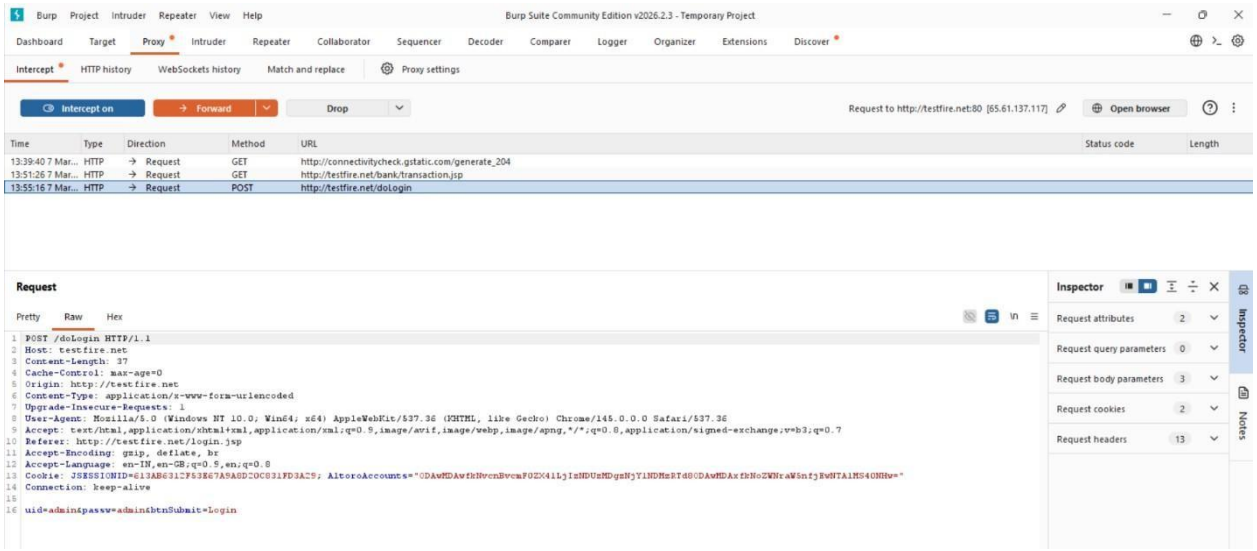
1. Open the website **http://testfire.net/**.
2. Login using admin credentials.
3. Capture the request using Burp Suite.
4. The username and password appear in clear text in the request.

Recommendation :

• Use HTTPS with SSL/TLS encryption.

• Ensure sensitive data is always transmitted securely.

Screenshot :



9. **Vulnerability Name : Clickjacking**

CWE No : CWE-1021

Description : Clickjacking occurs when a malicious webpage tricks users into clicking hidden buttons or links by placing the target webpage inside an invisible frame.

Business Impact : Attackers can trick users into performing unwanted actions such as clicking buttons, submitting forms, or revealing sensitive information.

Vulnerability Path : **http://testfire.net/** **Steps to Reproduce :**

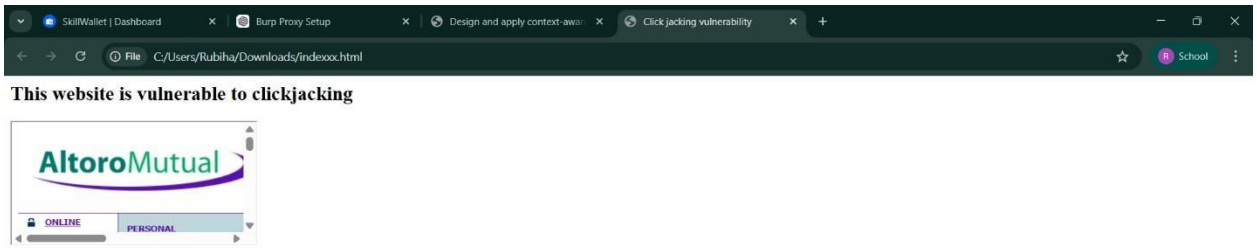
1. Open the target website **http://testfire.net/**.
2. Create an HTML page that loads the site inside an iframe.
3. Run the HTML file in a browser.
4. The website loads inside the frame, confirming the vulnerability.

Recommendation :

Use X-Frame-Options header to prevent framing.

Implement Content Security Policy (CSP) to block unauthorized embedding.

Screenshot :



10. Vulnerability Name : Web Server Allows Password Auto-Completion

CWE No : CWE-310SSS

Description : This vulnerability occurs when the web browser automatically fills previously saved usernames and passwords on login pages.

Business Impact : Attackers who gain access to the device can easily view or use stored credentials to access the application.

Vulnerability Path : **http://testfire.net/login.jsp** **Steps to Reproduce :**

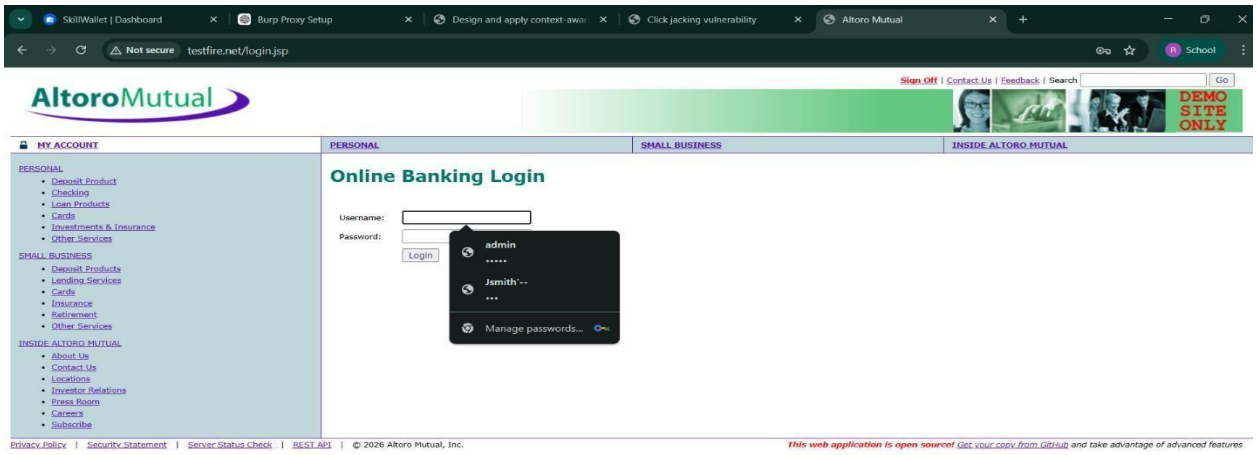
1. Open the website **http://testfire.net/**.
2. Navigate to the login page.
3. Click on the username or password field.
4. The browser automatically suggests stored credentials.

Recommendation :

Disable password auto-completion on login forms.

Use secure authentication mechanisms.

Screenshot :



11. Vulnerability Name : Cross-Site Scripting (DOM Based)

CWE No : CWE-79

Description : DOM-based XSS occurs when the client-side script processes user input and inserts it into the webpage without proper validation.

Business Impact : Attackers can execute malicious scripts in the user's browser and steal sensitive data such as session cookies. Vulnerability Path : **https://vit.ac.in/** **Steps to Reproduce :**

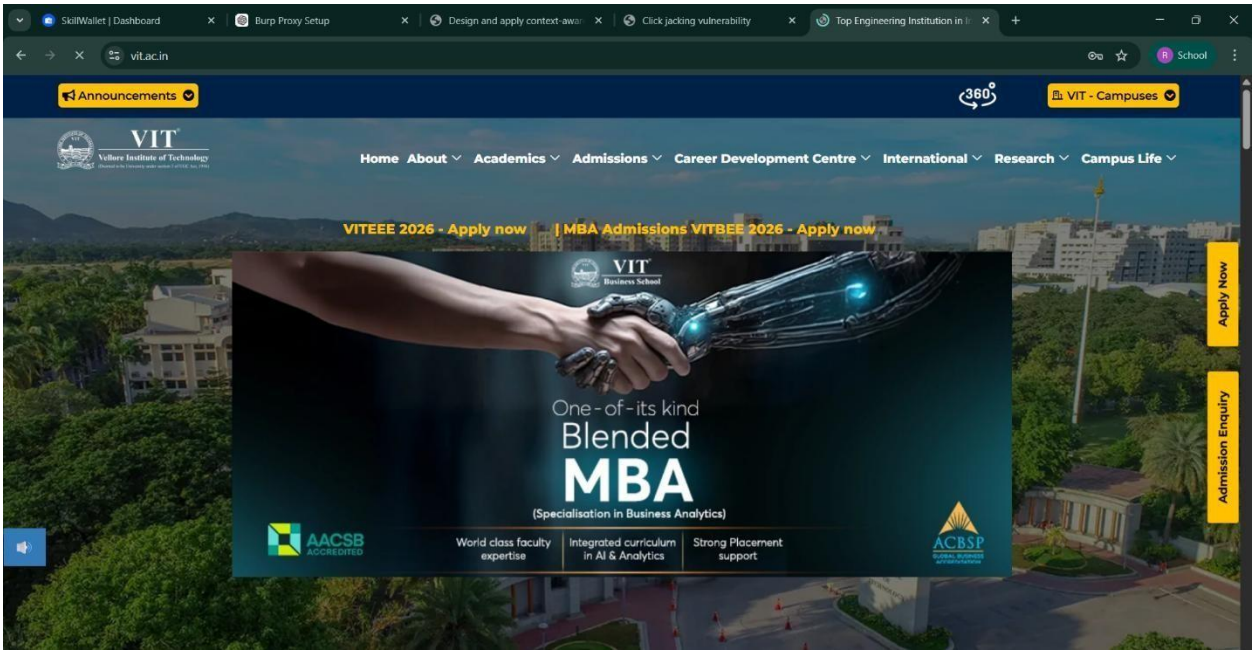
1. Open the website **https://vit.ac.in/**.
2. Inspect the page source using browser developer tools.
3. Identify places where user input is processed by JavaScript.
4. Inject malicious scripts to test for DOM manipulation.

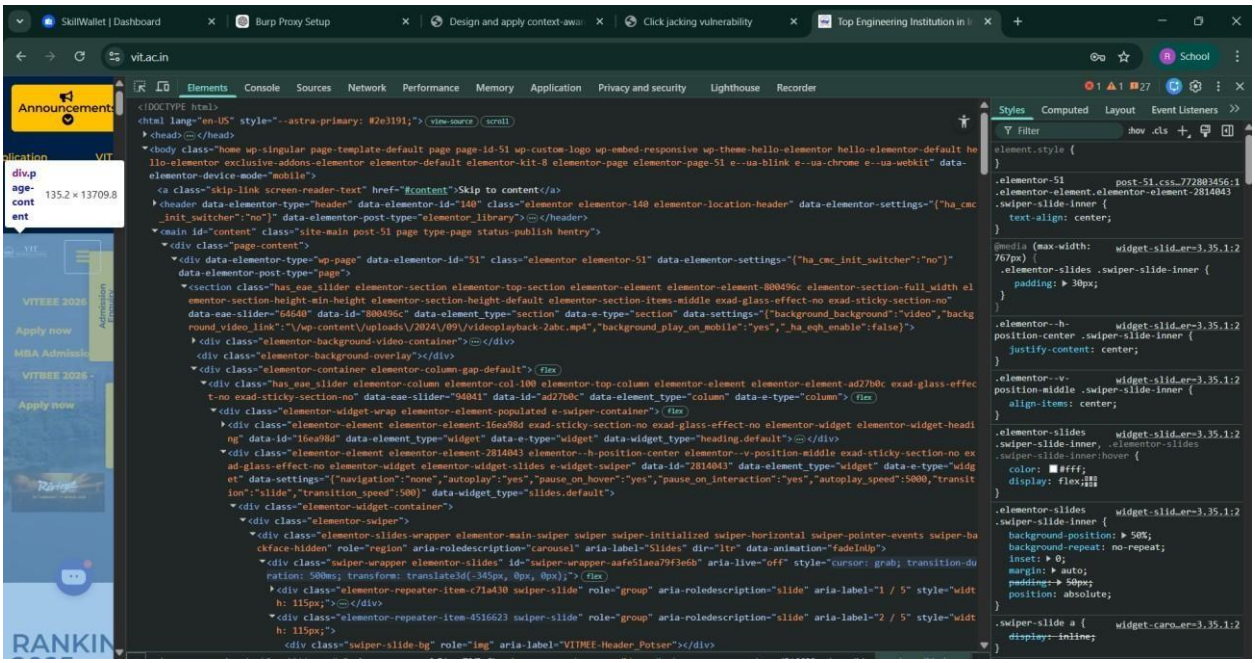
Recommendation :

Validate and sanitize user inputs.

Avoid unsafe DOM manipulation methods.

Screenshot :





12. Vulnerability Name : JQuery Multiple XSS

CWE No : CWE-79

Description : This vulnerability occurs when outdated versions of JQuery contain security flaws that allow attackers to execute malicious scripts.

Business Impact : Attackers can exploit these vulnerabilities to run harmful scripts in the user's browser and steal sensitive data.

Vulnerability Path : **https://vit.ac.in/sites/all/themes/vittheme/js/jquery-2.1.1.min.js**

Steps to Reproduce :

Open the website **https://vit.ac.in/**.

Access the JQuery script used by the website.

Identify the JQuery version in the source code.

Older JQuery versions may contain XSS vulnerabilities.

Recommendation :

Update JQuery to the latest secure version.

Regularly update libraries used in web applications.

Screenshot :

```
!function(e,t){"object"==typeof module&&"object"==typeof module.exports?module.exports=e.document?t(e,!0):function(e){if(!e.document)throw new Error("jQuery requires a window with a document");return
t(e)}:t(e)}("undefined"!=typeof window?window:this,function(e,t){var n=[],r=n.slice,i=n.concat,o=n.push,a=n.indexOf,s={},l=s.toString,u=s.hasOwnProperty,c={},d="1.11.1",f=function(e,t){return new
f.fn.init(e,t)},p=/^[\s\uFEFF\xA0]+|[\s\uFEFF\xA0]+$/g,h=/^-ms-/,m=/-([\da-z])/gi,g=function(e,t){return t.toUpperCase()};function v(e){var t=e.length,n=f.type(e);return"function"!==n&&!f.isWindow(e)&&(!
(1!==e.nodeType||!t)||("array"===n||0===t||"number"==typeof t&&t>0&&t-1 in e))}f.fn=f.prototype={jquery:d,constructor:f,selector:"",length:0,toArray:function(){return r.call(this)},get:function(e){return
null!=e?0>e?this[e+this.length]:this[e]:r.call(this)},pushStack:function(e){var t=f.merge(this.constructor(),e);return t.prevObject=this,t.context=this.context,t},each:function(e,t){return
f.each(this,e,t)},map:function(e){return this.pushStack(f.map(this,function(t,n){return e.call(t,n,t)}))},slice:function(){return this.pushStack(r.apply(this,arguments))},first:function(){return
this.eq(0)},last:function(){return this.eq(-1)},eq:function(e){var t=this.length,n=+e(0>e?t:0);return this.pushStack(n>=0&&t>n?[this[n]]:[])},end:function(){return
this.prevObject||this.constructor(null)},push:o,sort:n.sort,splice:n.splice},f.extend=f.fn.extend=function(){var e,t,n,r,i,o,a=arguments[0]||{},s=1,l=arguments.length,u=!1;for("boolean"==typeof a&&
(u=a,a=arguments[s]||{},s++),"object"==typeof a||f.isFunction(a)||(a={}),s===l&&(a=this,s--);l>s;s++)if(null!=(i=arguments[s]))for(r in i)e=a[r],a!==(n=i[r])&&(u&&n&&(f.isPlainObject(n)||(t=f.isArray(n)))?(t?
(t=!1,o=e&&f.isArray(e)?e:[]):o=e&&f.isPlainObject(e)?e:{},a[r]=f.extend(u,o,n)):void 0!==n&&(a[r]=n));return a},f.extend({expando:"jQuery"+(d+Math.random()).replace(/\D/g,""),isReady:!0,error:function(e){throw
new Error(e)},noop:function(){},isFunction:function(e){return"function"===f.type(e)},isArray:Array.isArray||function(e){return"array"===f.type(e)},isWindow:function(e){return
null!=e&&e==e.window},isNumeric:function(e){return!f.isArray(e)&&e-parseFloat(e)>=0},isEmptyObject:function(e){var t;for(t in e)return!1;return!0},isPlainObject:function(e){var
t;if(!e||"object"!==f.type(e)||e.nodeType||f.isWindow(e))return!1;try{if(e.constructor&&!u.call(e,"constructor")&&!u.call(e.constructor.prototype,"isPrototypeOf"))return!1}catch(e){return!1}if(c.ownLast)for(t
in e)return u.call(e,t);for(t in e);return void 0===t||u.call(e,t)},type:function(e){return null==e?e+"":"object"==typeof e||"function"==typeof e?s[l.call(e)]||"object":typeof e},globalEval:function(t)
{t&&f.trim(t)&&(e.execScript||function(t){(e.eval.call(e,t))}(t)),camelCase:function(e){return e.replace(h,"ms-").replace(m,g)},nodeName:function(e,t){return
e.nodeName&&e.nodeName.toLowerCase()===t.toLowerCase()},each:function(e,t,n){var r=0,i=e.length,o=v(e);if(n){if(o){for(;i>r&&!1!==t.apply(e[r],n);r++);else for(r in e)if(!1===t.apply(e[r],n))break}else
if(o){for(;i>r&&!1!==t.call(e[r],r,e[r]);r++);else for(r in e)if(!1===t.call(e[r],r,e[r]))break;return e},trim:function(e){return null==e?"":(e+"").replace(p,"")},makeArray:function(e,t){var n=t||[];return
null!=e&&(v(Object(e))?f.merge(n,"string"==typeof e?[e]:e):o.call(n,e)),n},inArray:function(e,t,n){var r;if(t){if(a)return a.call(t,e,n);for(r=t.length,n=n?0>n?Math.max(0,r+n):n:0;r>n;n++)if(n in
t&&t[n]===e)return n}return-1},merge:function(e,t){for(var n=+t.length,r=0,i=e.length;n>r;)e[i++]=t[r++];if(n!=n)for(;void 0!==t[r];)e[i++]=t[r++];return e.length=i,e},grep:function(e,t,n){for(var r=
[],i=0,o=e.length,a=!n;o>i;i++)!t(e[i],i)!=a&&r.push(e[i]);return r},map:function(e,t,n){var r,o=0,a=e.length,s=[];if(v(e))for(;a>o;o++)null!=(r=t(e[o],o,n))&&s.push(r);else for(o in e)null!=
(r=t(e[o],o,n))&&s.push(r);return i.apply([],s)},guid:1,proxy:function(e,t){var n,i,o;return"string"==typeof t&&(o=e[t],t=e,e=o),f.isFunction(e)?(n=r.call(arguments,2),(i=function(){return
e.apply(t||this,n.concat(r.call(arguments)))})).guid=e.guid=e.guid||f.guid++,i):void 0},now:function(){return+new Date},support:c})},f.each("Boolean Number String Function Array Date RegExp Object Error".split("
"),function(e,t){s["[object "+t+"]"]=t.toLowerCase()});var y=function(e){var t,n,r,i,o,a,s,l,u,c,d,f,p,h,m,g,v,y,b,x="sizzle"+-new Date,w=e.document,T=0,C=0,N=oe(),E=oe(),k=oe(),S=function(e,t){return e===t&&
{d=!0},0},A="undefined",D=1<<31,j={}.hasOwnProperty,L=[],H=L.pop,_=L.push,q=L.push,M=L.slice,O=L.indexOf||function(e){for(var t=0,n=this.length;n>t;t++)if{this[t]===e}return t;return-
1},F="checked|selected|async|autofocus|autoplay|controls|defer|disabled|hidden|ismap|loop|multiple|open|readonly|required|scoped",B="[\\x20\\t\\r\\n\\f]",P="(?:\\\\.|[\\w-]|[^\\x00-
\\xa0])+",R=P.replace("w","w#"),W="\\[".+B+"*("+P+")(?:".+B+"*([*^$|!~]?=)".+B+"*(?:'((?:\\\\.|[^\\\\']|".+B+")*)'|\"((?:\\\\.|[^\\\\"]|".+B+")*)\"|(".+B+"))|)".+B+"*\\]",$=":("+P+")(?:\\(((('((?:\\\\.|[^\\\\']|".+B+")*)'|\"((?:\\\\.|
[^\\\\"]|".+B+")*)\")|((?:\\\\.|[^\\\\()[\\]]|".+W+")*)|.*)\\)|)",z=new RegExp(".+B+"+|((?:^|[^\\\\])(?:\\\\.)*)".+B+"$","g"),I=new RegExp("^".+B+"*,".+B+"*"),X=new RegExp("^".+B+"*([>+~]|".+B+")".+B+"*"),U=new
RegExp("~=".+B+"*((?:\\)|\"|*2)".+B+"*\)","g"),V=new RegExp($),J=new RegExp("^".+R+"$"),Y={ID:new RegExp("^#(".+P+")"),CLASS:new RegExp("^\\.(".+P+")"),TAG:new RegExp("^(".+P.replace("w","w*")+")"),ATTR:new
RegExp("^".+W),PSEUDO:new RegExp("^".+$),CHILD:new RegExp("^:(only|first|last|nth|nth-last)-(child|of-type)(?:\\(".+B+"*(even|odd|((([+-]|)(\\d*n|)".+B+"*(?:([+-]|)(\\d*n)".+B+"*\\)|)(?=
[^-]|$)","i"),G=/^(?:input|select|textarea|button)$/i,Q=/^h\d$/i,K=/^[^{]+\{\s*\[native \w/,Z=/^(?:#([\w-]+)|(\w+)|\.([\w-]+))$/,ee=/[+~]/,te=/'|\\/g,ne=new RegExp("\\\\([\\da-f]{1,6}".+B+"?|
(".+B+")|.)","ig"),re=function(e,t,n){var r="0x"+t-65536;return r!=r||n?t:0>r?
String.fromCharCode(r+65536):String.fromCharCode(r>>10|55296,1023&r|56320)};try{q.apply(L=M.call(w.childNodes),w.childNodes),L[w.childNodes.length].nodeType}catch(e){q={apply:L.length?function(e,t)
{_.apply(e,M.call(t))}:function(e,t){for(var n=e.length,r=0;e[n++]=t[r++];);e.length=n-1}}function ie(e,t,r,i){var o,s,u,c,d,h,v,y,T,C;if((t?t.ownerDocument||t:w)!==p&&f(t),r=r||[],!e||"string"!=typeof
e)return r;if(1!==(c=(t=t||p).nodeType)&&9!==c)return[];if(m&&!i){if(o=Z.exec(e))if(u=o[1]){if(9===c){if(!(s=t.getElementById(u)))||!s.parentNode)return r;if(s.id===u)return r.push(s),r}else if(t.ownerDocument&&
(s=t.ownerDocument.getElementById(u))&&b(t,s)&&s.id===u)return r.push(s),r}else if(o[2])return q.apply(r,t.getElementsByTagName(e)),r;if((u=o[3])&&n.getElementsByClassName&&t.getElementsByClassName)return
q.apply(r,t.getElementsByClassName(u)),r}if(n.qsa&&!!g||!g.test(e)){if(y=v=x,T=t,C=9===c&&e,1===c&&"object"!=t.nodeName.toLowerCase()){for(h=a(e),(v=t.getAttribute("id"))?
y=v.replace(te,"\\$&"):t.setAttribute("id",y),y="[id='"+y+"'] ",d=h.length;d--;)h[d]=y+ve(h[d]);T=ee.test(e)&&pe(t.parentNode)||t,C=h.join(",")}if(C)try{return q.apply(r,T.querySelectorAll(C)),r}catch(e)
{}}finally{v||t.removeAttribute("id")}}return l(e.replace(z,"$1"),t,r,i)}function oe(){var e=[];return function t(n,i){return e.push(n+" ")>r.cachelength&&delete t[e.shift()],t[n+" "]=i}}function ae(e){return
e[x]=!0,e}function se(e){var t=p.createElement("div");try{return!!e(t)}catch(e){return!1}finally{t.parentNode&&t.parentNode.removeChild(t),t=null}}function le(e,t){for(var n=e.split("|"),i=e.length;i-
-;)r.attrHandle[n[i]]=t}function ue(e,t){var n=t&&e,r=n&&1===e.nodeType&&1===t.nodeType&&(~t.sourceIndex||D)-(~e.sourceIndex||D);if(r)return r;if(n)for(;n=n.nextSibling;)if(n===t)return-1;return e?1:-1}functio
ce(e){return function(t){return"input"===t.nodeName.toLowerCase()&&t.type===e}}function de(e){return function(t){var n=t.nodeName.toLowerCase();return("input"===n||"button"===n)&&t.type===e}}function fe(e)
{return ae(function(t){return t=+t,ae(function(n,r){for(var i,o=e([],n.length,t),a=o.length;a--;)n[i=o[a]]&&(n[i]=!(r[i]=n[i]))})})}function pe(e){return e&&typeof e.getElementsByTagName!=="A&&e}for(t in
n=ie.support={},o=ie.isXML=function(e){var t=e&&(e.ownerDocument||e).documentElement;return!!t&&"HTML"!=t.nodeName},f=ie.setDocument=function(e){var t,i=e?e.ownerDocument||e:w,a=i.defaultView;return
i!=p&&9===i.nodeType&&i.documentElement?(p=i,h=i.documentElement,m=!o(i),a&&a!==a.top&&(a.addEventListener?a.addEventListener("unload",function(){f()},!1):a.attachEvent&&a.attachEvent("onunload",function()
```

13. Vulnerability Name : Information Exposure (Web Server HTTP Header Internal IP Disclosure)

CWE No : CWE-200

Description : This vulnerability occurs when the web server reveals internal IP addresses or system information in HTTP response headers.

Business Impact : Attackers can use this internal information to identify the system structure and plan further attacks on the network. Vulnerability Path : https://vit.ac.in/ **Steps to Reproduce :**

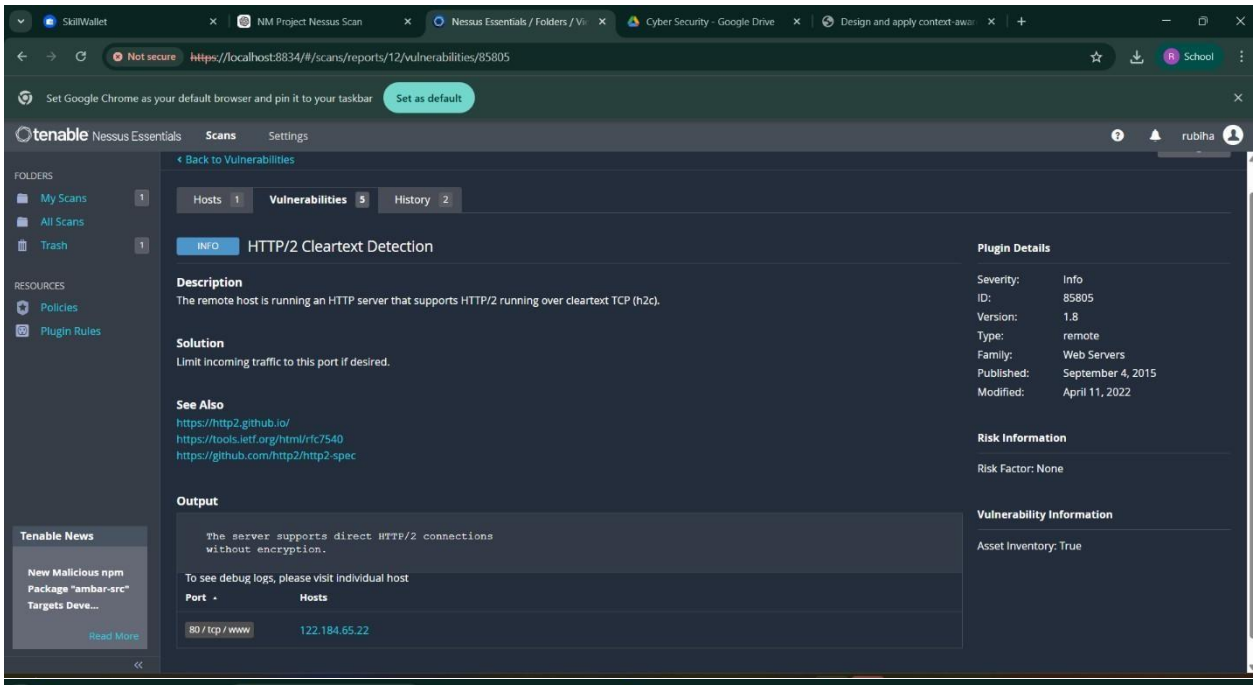
1. Open the target website.
2. Scan the website using Nessus vulnerability scanner.
3. Analyze the HTTP response headers.
4. The scan reveals the internal IP address of the server.

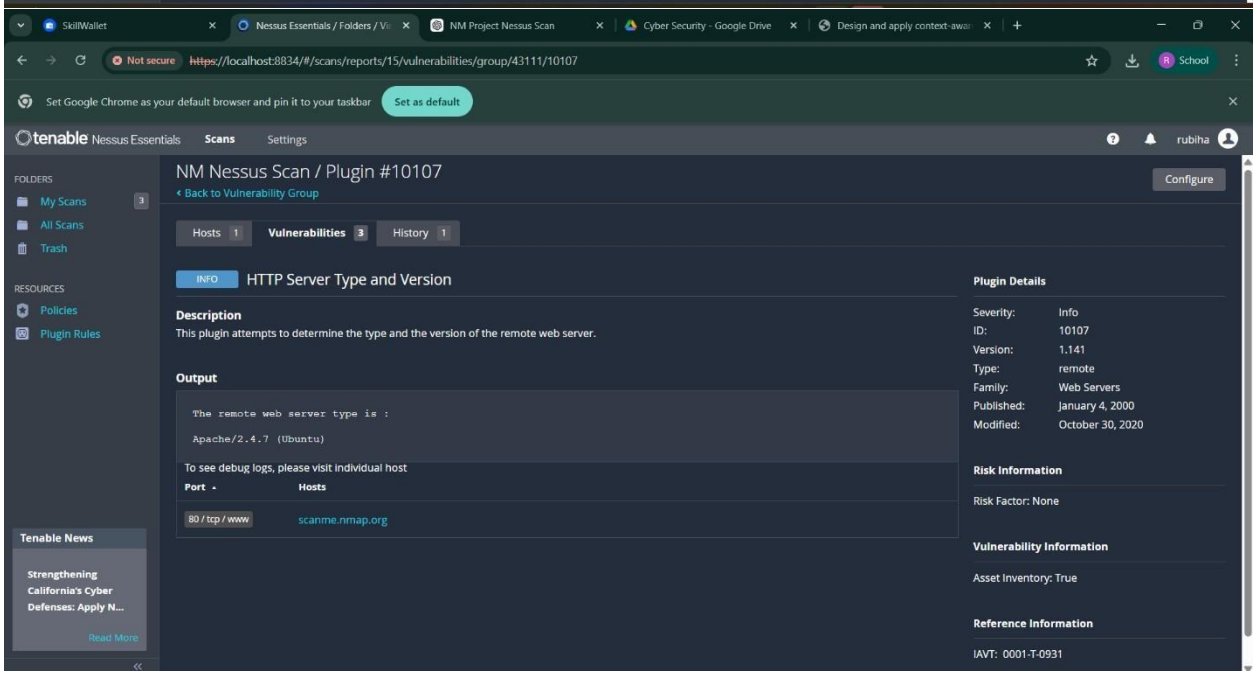
Recommendation :

Configure the web server to hide internal IP addresses.

Remove unnecessary information from HTTP response headers.

Screenshot :





14. Vulnerability Name : Information Exposure (SSL Multiple Issues)

CWE No : CWE-200

Description : This vulnerability occurs when the SSL/TLS configuration of a website exposes sensitive encryption details or uses weak security protocols.

Business Impact : Weak SSL configurations can allow attackers to intercept encrypted communication and access sensitive data.

Vulnerability Path : **https://vit.ac.in/** **Steps to Reproduce :**

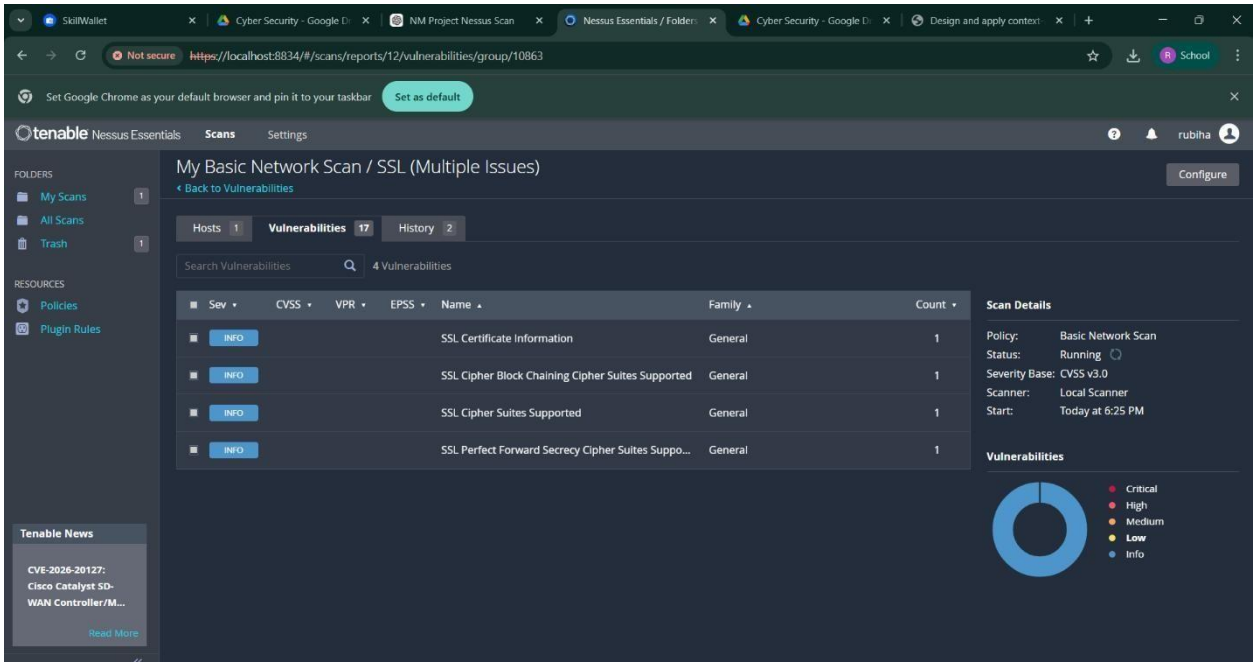
1. Open the target website.
2. Scan the website using Nessus vulnerability scanner.
3. Analyze the SSL/TLS configuration details.
4. The scan shows issues related to encryption protocols.

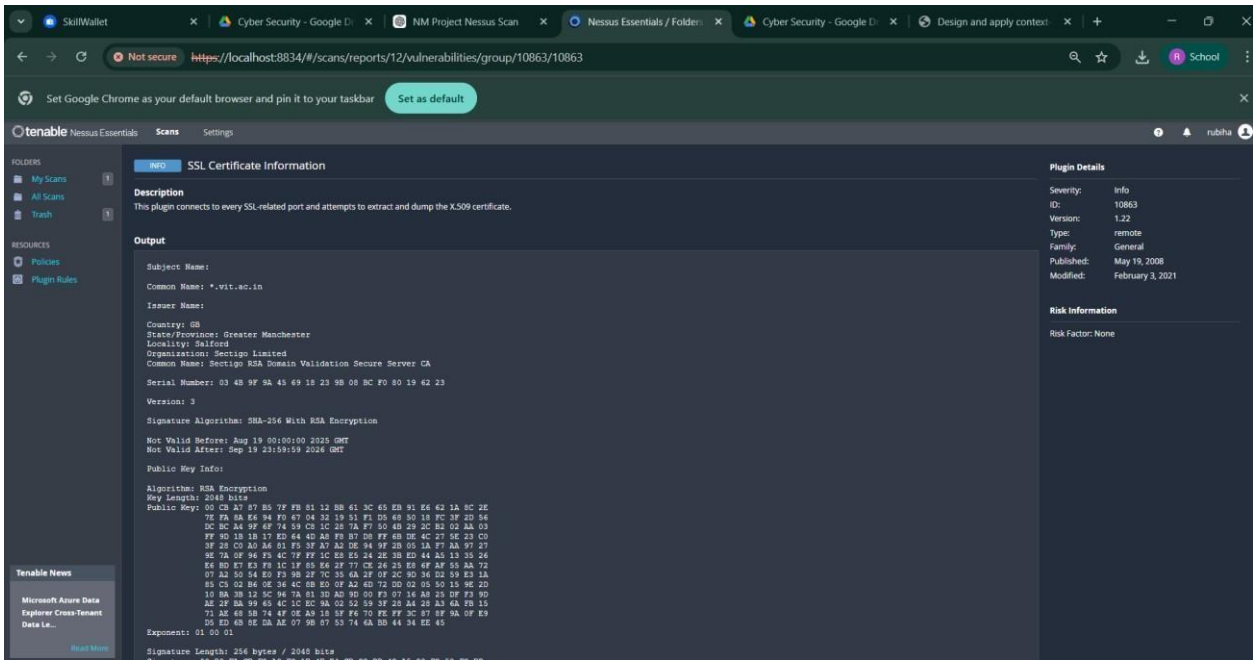
Recommendation :

Use strong encryption protocols such as TLS 1.2 or higher.

Disable outdated protocols like SSLv3.

Screenshot :





15. Vulnerability Name : Information Exposure (HTTP Multiple Issues)

CWE No : CWE-200

Description : This vulnerability occurs when the web server reveals unnecessary information through HTTP responses such as server details and protocol information.

Business Impact : Attackers can gather system information which may help them identify weaknesses and launch further attacks.

Vulnerability Path : **https://vit.ac.in/** **Steps to Reproduce :**

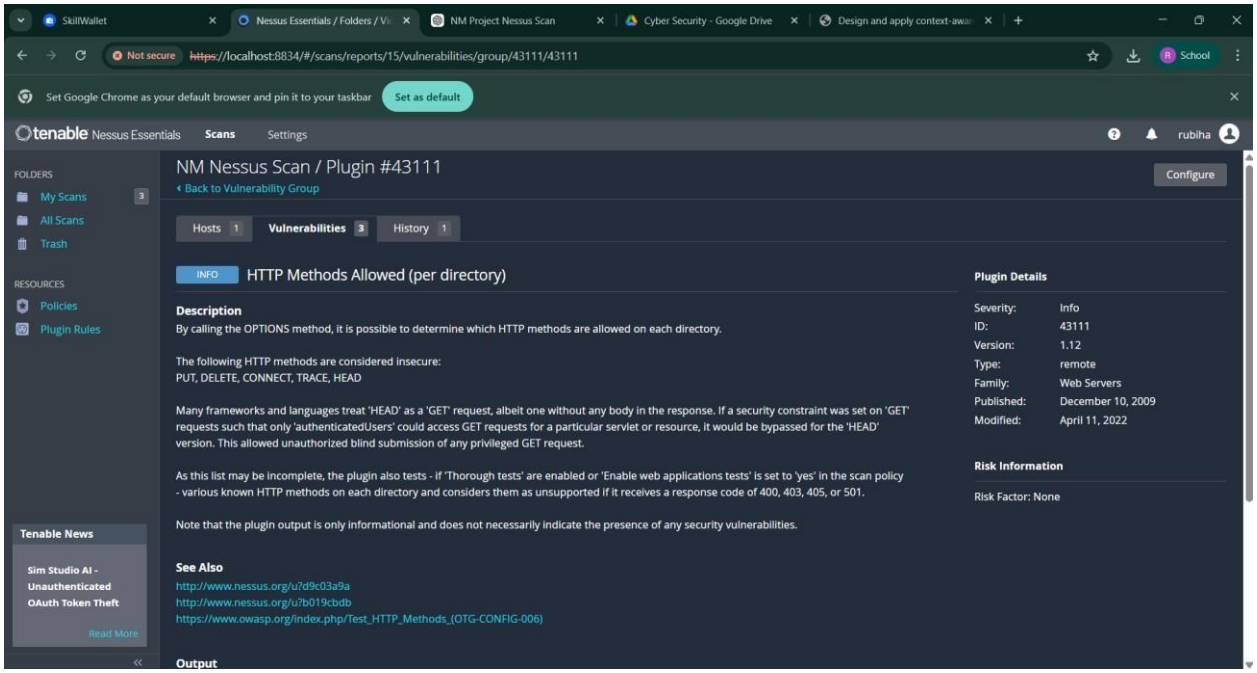
1. Open the target website.
2. Scan the website using Nessus scanner.
3. Review the HTTP response details.
4. The scan reveals server information and protocol details.

Recommendation :

Reduce unnecessary information in HTTP responses.

Use secure HTTPS configuration for communication.

Screenshot :



16. Vulnerability Name : OS Identification Failed

CWE No : CWE-200

Description : OS Identification Failed occurs when a vulnerability scanning tool cannot accurately detect the operating system of the target server.

Business Impact : Incorrect system identification may lead to improper security analysis and may hide potential vulnerabilities in the system.

Vulnerability Path : **https://vit.ac.in/** **Steps to Reproduce :**

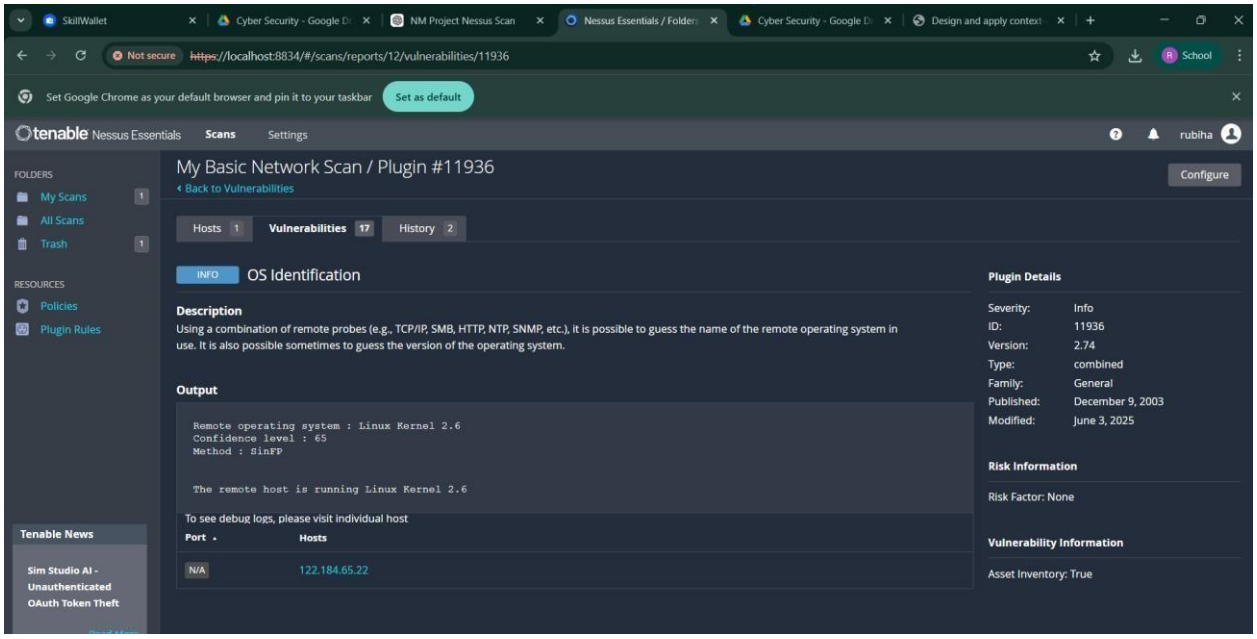
1. Open the target website.
2. Perform a vulnerability scan using Nessus scanner.
3. Analyze the scan results.
4. The scanner fails to identify the operating system of the target server.

Recommendation :

Ensure proper system configuration for accurate scanning.

Perform regular vulnerability assessments to detect security issues.

Screenshot :



STAGE 2

In this stage, vulnerability scanning and security analysis were performed to identify potential security weaknesses in the target web application. The objective of this stage is to detect vulnerabilities that may allow attackers to gain unauthorized access or expose sensitive information.

Security testing was conducted using vulnerability assessment tools such as Nessus Scanner along with manual analysis techniques. These tools help in scanning the web server, identifying vulnerabilities, and analyzing the security posture of the application.

The scan results provide information about different types of vulnerabilities along with their severity levels. The identified issues include Cross-Site Scripting, information exposure, and configuration-related vulnerabilities.

The following table shows the vulnerabilities detected during the scanning process.

S. No	Vulnerability Name	Severity	Plugin
1	Cross-Site Scripting (DOM	Medium	Multiple XSS
2	jQuery 1.3 < 3.5.0 Multiple	Medium	CGI Abuse: XSS
3	Information Exposure (We Header Internal IP Disclos	Low	Webserver HTTP Header Internal IP Disclosure
4	Information Exposure (SSL	Info	SSL Certificate Information
5	Information Exposure (HT	Info	HTTP Information
6	OS Identification Failed	Info	TCP/IP Remote Probing

Explanation Of Detected Vulnerabilities

1. **Cross-Site Scripting (DOM Based XSS) – Medium Severity**

DOM-based Cross-Site Scripting occurs when user input is processed directly in the browser using JavaScript without proper validation or sanitization. This allows attackers to inject malicious scripts that execute in the user's browser. Such attacks can lead to session hijacking, cookie theft, or unauthorized actions performed on behalf of the user. Proper input validation and secure coding practices can help prevent this vulnerability.

2. **jQuery 1.3 < 3.5.0 Multiple XSS – Medium Severity**

This vulnerability occurs when a website uses outdated versions of the jQuery library that contain known security flaws. These vulnerabilities can allow attackers to execute Cross-Site Scripting attacks through manipulated inputs. Updating the jQuery library to the latest secure version and regularly maintaining third-party components can help mitigate this issue.

3. **Information Exposure (Web Server HTTP Header Internal IP Disclosure) – Low Severity**

This vulnerability occurs when the web server exposes internal IP addresses or sensitive system information through HTTP response headers. Attackers can use this information to understand the internal network structure and plan targeted attacks. Configuring the web server to hide internal IP details and unnecessary header information can reduce this risk.

4. **Information Exposure (SSL Multiple Issues) – Informational**

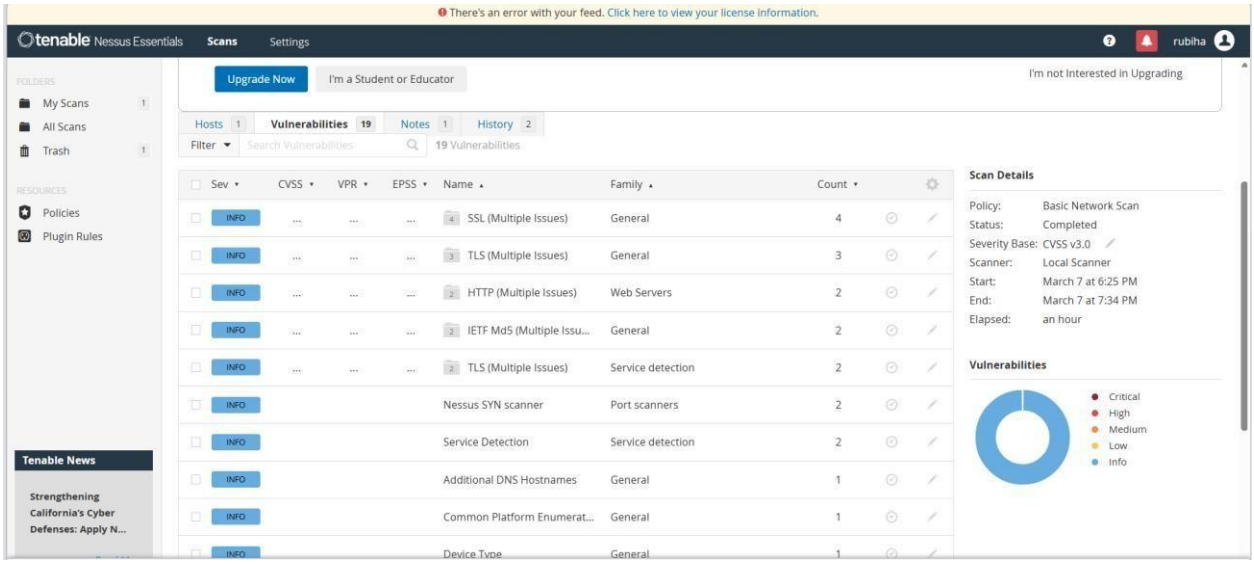
This issue indicates that the SSL/TLS configuration of the web server may reveal details about encryption settings or certificates. Although it may not directly lead to exploitation, it provides useful information to attackers about the server's security configuration. Ensuring proper SSL configuration and using strong encryption protocols such as TLS 1.2 or higher can improve security.

5. **Information Exposure (HTTP Multiple Issues) – Informational**

This vulnerability indicates that the web server exposes additional HTTP information such as server details, protocol versions, or configuration data. Attackers can use this information to identify potential weaknesses in the system. Reducing unnecessary server information and properly configuring HTTP responses can help prevent such exposure.

6. **OS Identification Failed – Informational**

This issue indicates that the vulnerability scanning tool was unable to accurately identify the operating system of the target server. While this does not represent a direct security vulnerability, it may indicate network filtering, restricted responses, or incomplete system information. Proper configuration and accurate system identification can help improve vulnerability assessment results.



STAGE 3

RESULTS AND SECURITY RECOMMENDATIONS

After completing the vulnerability scanning and analysis process, several security issues were identified in the target web application. The vulnerability assessment was performed using tools such as Nessus Scanner, Burp Suite, and manual testing techniques. The scan results revealed

different types of vulnerabilities including Cross-Site Scripting (XSS), outdated JavaScript libraries, information exposure through HTTP headers, and configuration-related issues.

The vulnerability scan categorized the issues into different severity levels such as Medium, Low, and Informational. Medium-level vulnerabilities like DOM-Based Cross-Site Scripting and outdated jQuery versions can allow attackers to execute malicious scripts in the user's browser. These vulnerabilities can potentially lead to session hijacking, data theft, or unauthorized access.

Low-level vulnerabilities such as HTTP header internal IP disclosure may expose sensitive server details. Attackers can use this information to better understand the system architecture and plan further attacks on the web server.

Informational vulnerabilities including SSL certificate details, HTTP information disclosure, and OS identification failures provide additional information about the server environment. While these vulnerabilities may not directly lead to attacks, they can assist attackers in gathering intelligence about the system.

To improve the overall security of the application, several security recommendations are suggested. Web developers should implement proper input validation and output encoding to prevent injection attacks such as Cross-Site Scripting. Outdated libraries such as older versions of jQuery should be updated to the latest secure versions to eliminate known vulnerabilities.

Additionally, server configuration should be improved by hiding sensitive HTTP headers and internal IP addresses. Secure communication protocols such as HTTPS with strong SSL/TLS encryption should be used to protect data transmitted over the network. Regular security testing and vulnerability scanning should also be performed to identify new threats and ensure continuous protection of the system.

By implementing these security practices, organizations can significantly reduce the risk of cyberattacks and maintain a secure environment for users and applications.

TOOLS USED

The project involved the use of several cybersecurity tools and technologies to perform vulnerability scanning and security analysis. These tools help security professionals identify weaknesses in web applications and understand potential attack vectors.

Kali Linux : Kali Linux is a penetration testing operating system that contains a large collection of cybersecurity tools used for ethical hacking, vulnerability analysis, and network security testing.
It provides an environment for performing security assessments on systems and web applications.

Nessus Vulnerability Scanner : Nessus is a widely used vulnerability scanning tool that detects security flaws, misconfigurations, and outdated software components in servers and web applications. It provides detailed reports that include vulnerability descriptions, severity levels, and remediation recommendations.

Burp Suite : Burp Suite is a web application security testing tool used to intercept, inspect, and modify HTTP requests and responses between the browser and the web server. It helps identify vulnerabilities such as SQL Injection, Cross-Site Scripting, and authentication issues.

Web Browser : A web browser such as Google Chrome or Mozilla Firefox is used to access the target web application and perform manual security testing. Browser developer tools help inspect web page elements and analyze scripts.

Uniscan Tool : Uniscan is a web vulnerability scanning tool used to detect hidden directories, configuration issues, and potential vulnerabilities in web applications.

These tools collectively help security analysts perform effective vulnerability assessments and improve the overall security posture of web applications.

CONCLUSION

The main objective of this project was to design and apply context-aware access control concepts while performing vulnerability assessment on web applications. With the rapid growth of digital technologies and online services, cybersecurity has become an essential requirement for protecting sensitive data and system resources.

Through this project, various web application vulnerabilities were identified and analyzed using security testing tools. The vulnerability scanning process helped in understanding how attackers exploit weaknesses in web applications and how these vulnerabilities can impact the security of an organization.

The analysis revealed several vulnerabilities including Cross-Site Scripting, outdated software components, information exposure issues, and configuration weaknesses. Each vulnerability highlights the importance of implementing secure coding practices, proper system configuration, and regular security testing.

This project demonstrates the role of vulnerability assessment and security testing in improving application security. By identifying and addressing security weaknesses, organizations can prevent potential cyberattacks, protect user data, and maintain system integrity.

Overall, the project emphasizes the importance of proactive security measures, continuous monitoring, and regular vulnerability scanning to ensure a secure digital environment. Implementing strong security policies and modern access control mechanisms will help organizations protect their systems against evolving cyber threats.